

Wi-Fi Training Program

Module 6 – Assignment Questions & Answers

Sri Ragavendra S

1. What are the pillars of Wi-Fi security?

Answer:

Wi-Fi security is built on four fundamental pillars that together ensure a wireless network is protected from unauthorized access, eavesdropping, and data tampering.

1. Authentication – Who are you?

- Authentication verifies the identity of a device or user before allowing access to the network.
- Personal (PSK): The client proves knowledge of a pre-shared passphrase. Used in homes and small offices.
- Enterprise (802.1X/EAP): The client authenticates against a RADIUS server using credentials (username/password, certificates, or smart cards). Used in corporate and campus networks.
- WPA3-SAE: Replaces PSK with a zero-knowledge proof — the passphrase is never directly transmitted or exposed.
- Without authentication, any device could join the network.

2. Encryption – Protecting data in transit

- Encryption ensures that even if wireless frames are captured by a third party, the content cannot be read.
- WEP: RC4-based — broken and deprecated.
- TKIP (WPA): RC4 with per-packet key mixing — also deprecated.
- CCMP/AES (WPA2): AES-128 in Counter Mode with CBC-MAC — current standard.
- GCMP/AES (WPA3): AES-128/256 in Galois/Counter Mode — stronger and more efficient.
- Encryption protects confidentiality of data on the wireless medium.

3. Data Integrity – Detecting tampering

- Integrity mechanisms ensure that frames have not been modified in transit.
- WEP used CRC-32 — easily forged, not cryptographically secure.
- WPA/TKIP introduced MIC (Message Integrity Code) using the Michael algorithm — better but still vulnerable.
- WPA2/CCMP uses CBC-MAC for integrity — cryptographically strong.
- WPA3/GCMP uses GHASH — even stronger integrity protection.
- Without integrity checks, an attacker could modify packets in transit without detection.

4. Key Management – Secure key generation and distribution

- Even with strong encryption, the keys must be generated, distributed, and refreshed securely.
- The EAPOL 4-Way Handshake derives unique per-session encryption keys (PTK, GTK) from the PMK.
- Keys are never transmitted directly — they are derived independently on both sides using shared values and random nonces.
- GTK rotation: The AP periodically refreshes the Group Temporal Key (used for broadcast/multicast) to limit the exposure window if a key is compromised.
- WPA3 adds Forward Secrecy — even if the passphrase is later revealed, past session traffic cannot be decrypted.

Additional Pillar: Management Frame Protection (MFP/PMF)

- 802.11w (Protected Management Frames) extends integrity protection to management frames like Deauthentication and Disassociation.
- Without PMF, an attacker can forge deauth frames to kick clients off the network.

- WPA3 mandates PMF — it is optional in WPA2.

2. Explain the difference between authentication and encryption in Wi-Fi security.

Answer:

Aspect	Authentication	Encryption
Definition	Process of verifying the identity of a device or user before granting network access	Process of encoding data so it cannot be read by unauthorized parties
Purpose	Answers: Who are you? Are you allowed in?	Answers: Can anyone read your data?
When it happens	Before data transfer — during the connection/join process	During data transfer — every frame is encrypted once keys are established
What it protects against	Unauthorized access — prevents unknown devices from joining	Eavesdropping — prevents captured frames from being read
WPA2-Personal method	PSK verification via EAPOL 4-Way Handshake MIC check	AES-CCMP with the Temporal Key (TK) derived from PTK
WPA2-Enterprise method	EAP + RADIUS server (username/password, certificates)	AES-CCMP — same encryption, different key derivation path
WPA3 method	SAE (Simultaneous Authentication of Equals)	AES-GCMP-128/256
Key output	Produces PMK (Pairwise Master Key) as proof of authentication	Uses TK (Temporal Key, part of PTK) derived after authentication
Analogy	Showing your ID at the door to prove who you are	Speaking in a coded language once inside so others can't understand

Key Relationship:

Authentication and encryption are sequential — authentication must succeed first to establish the PMK, which is then used in the 4-Way Handshake to derive the encryption keys (PTK/GTK). You cannot have proper Wi-Fi encryption without authentication, and authentication alone without encryption leaves your data exposed on the air.

3. Explain the differences between WEP, WPA, WPA2, and WPA3.

Answer:

Feature	WEP	WPA	WPA2	WPA3
Year Introduced	1997	2003	2004	2018
Standard	802.11 (original)	802.11i (interim)	802.11i (full)	802.11i + SAE
Encryption Algorithm	RC4 (stream cipher)	RC4 + TKIP	AES-CCMP	AES-GCMP-128/256
Key Length	40-bit or 104-bit	128-bit per-packet	128-bit (AES)	128-bit or 256-bit
IV (Init Vector)	24-bit (reused rapidly)	48-bit (extended)	N/A (CCMP uses PN)	N/A (GCMP uses PN)
Integrity Check	CRC-32 (not secure)	Michael MIC	CBC-MAC (CCMP)	GHASH (GCMP)

Feature	WEP	WPA	WPA2	WPA3
Personal Auth	Shared Key (static)	PSK (Pre-Shared Key)	PSK (Pre-Shared Key)	SAE (Dragonfly handshake)
Enterprise Auth	Not supported	802.1X / EAP	802.1X / EAP	802.1X / EAP-TLS (Suite B)
PMF (Mgmt Frame Protection)	None	None	Optional (802.11w)	Mandatory
Forward Secrecy	No	No	No	Yes (SAE)
Status	Completely broken — deprecated 2004	Deprecated — transitional only	Current standard — widely deployed	Latest standard — recommended
Main Vulnerability	IV reuse, key recovery in minutes	TKIP weak against injection attacks	KRACK (Key Reinstallation), PMKID attack	Side-channel attacks on SAE (mitigated in updates)

Summary of Evolution:

- WEP was the first attempt at wireless security but was fundamentally broken due to weak RC4 implementation and short, reused IVs. It could be cracked in under 60 seconds with available tools.
- WPA was an emergency patch to replace WEP while 802.11i was being finalized. It kept RC4 but added TKIP for per-packet key mixing — better but not truly secure.
- WPA2 was the full implementation of 802.11i, replacing RC4 entirely with AES-CCMP. It remains secure when properly configured with strong passphrases and PMF enabled.
- WPA3 addresses WPA2's weaknesses — particularly offline dictionary attacks — by replacing PSK with SAE, mandating PMF, and adding forward secrecy.

4. Why is WEP considered insecure compared to WPA2 or WPA3?

Answer:

WEP (Wired Equivalent Privacy) was designed in 1997 to provide security equivalent to a wired connection. It failed completely due to fundamental flaws in its design and implementation. Here is a detailed breakdown of its weaknesses:

1. Weak Initialization Vector (IV):

- WEP uses a 24-bit IV (Initialization Vector) prepended to the static key to create a per-packet encryption key.
- 24 bits means only 16,777,216 possible IV values. On a busy network, all IVs are exhausted and begin repeating within hours.
- When the same IV is reused with the same key, an attacker can XOR two ciphertexts to eliminate the key and analyze the plaintexts — this is a known-plaintext attack.
- WPA2 uses a 48-bit Packet Number (PN) with AES-CCMP — IV reuse is essentially impossible.

2. Weak Encryption Algorithm (RC4):

- WEP uses the RC4 stream cipher, which is weak when used with short, related keys.
- The first few bytes of the RC4 keystream are biased and reveal information about the key — known as the Fluhrer, Mantin and Shamir (FMS) attack.
- Tools like Aircrack-ng can crack a WEP key by collecting as few as 5,000–40,000 IV packets — achievable in minutes on a busy network.
- WPA2 uses AES (Advanced Encryption Standard) — a symmetric block cipher with no known practical attacks.

3. No Cryptographic Integrity (CRC-32):

- WEP uses CRC-32 for integrity — this is a checksum designed to detect accidental errors, not deliberate tampering.
- CRC-32 is linear — an attacker can predictably modify an encrypted frame and update the CRC without knowing the key.
- This allows bit-flipping attacks where an attacker modifies specific bytes in the payload (e.g., changing an IP address) without being detected.
- WPA2's AES-CCMP uses CBC-MAC — a cryptographic integrity check that cannot be forged without knowing the key.

4. Static Keys:

- WEP uses the same key for all devices and all time — once the key is discovered, all traffic (past and future) is compromised.
- There is no per-session key derivation — the key is manually configured and rarely changed.
- WPA2 derives unique per-session PTKs for every client using the 4-Way Handshake — compromise of one session key does not affect others.
- WPA3 adds forward secrecy — even the passphrase being revealed later cannot decrypt past sessions.

5. No Authentication of Management Frames:

- WEP provides no protection for management frames — deauthentication and disassociation frames can be forged by anyone.
- WPA2 (with PMF/802.11w) and WPA3 (mandatory PMF) protect management frames cryptographically.

5. Why was WPA2 introduced?

Answer:

Background:

WPA2 was introduced in 2004 as the full and mandatory implementation of the IEEE 802.11i security standard. It was developed because both WEP and WPA had serious and well-documented security vulnerabilities that made them unsuitable for protecting wireless networks.

Reasons WPA2 Was Introduced:

- **WEP Was Completely Broken:** By the early 2000s, WEP keys could be cracked in minutes using freely available tools. It provided no meaningful security.
- **WPA Was Only a Temporary Fix:** WPA was an emergency measure developed quickly while 802.11i was being finalized. It retained the weak RC4 cipher (with TKIP improvements) but was never intended to be a long-term solution. TKIP itself was later found to be vulnerable to specific injection attacks.
- **Need for Strong Encryption:** The industry needed AES (Advanced Encryption Standard) — a NIST-approved, mathematically strong cipher. AES-CCMP (Counter Mode with CBC-MAC Protocol) was incorporated as the mandatory encryption method in WPA2.
- **Need for Proper Key Management:** WPA2 introduced the full EAPOL 4-Way Handshake for deriving per-session, per-client encryption keys — ensuring that no two sessions use the same keys.
- **Enterprise Security Support:** WPA2 provided full support for 802.1X/EAP-based authentication with RADIUS servers, enabling proper identity-based access control for corporate networks.
- **Mandatory Certification:** From March 2006, Wi-Fi Alliance mandated WPA2 certification for all new Wi-Fi devices — ensuring a baseline security standard across the industry.
- **Government and Industry Compliance:** Standards like FIPS 140-2 and various regulatory frameworks required AES encryption, which only WPA2 provided.

What WPA2 Improved Over WPA:

Aspect	WPA	WPA2
Encryption	RC4 + TKIP	AES-CCMP (mandatory)
Integrity	Michael MIC (weak)	CBC-MAC (strong, cryptographic)
Standard basis	Subset of 802.11i (draft)	Full 802.11i implementation
TKIP support	Mandatory	Optional (for backward compatibility only)
Enterprise support	802.1X / EAP	802.1X / EAP (full, proper implementation)

6. What is the role of the Pairwise Master Key (PMK) in the 4-Way Handshake?

Answer:

What is the PMK?

The Pairwise Master Key (PMK) is a 256-bit cryptographic key that serves as the root secret shared between the client and the AP. It is the starting point from which all session encryption keys are derived during the EAPOL 4-Way Handshake.

How the PMK is Obtained:

- WPA2-Personal (PSK): PMK = PBKDF2-SHA1(Passphrase, SSID, 4096 iterations, 256 bits). The PMK is derived from the Wi-Fi password and SSID. Both the AP and client derive the same PMK independently — the passphrase is never transmitted over the air.
- WPA2-Enterprise (802.1X): After successful EAP authentication with the RADIUS server, the server generates the PMK and securely delivers it to the AP. The client also derives the same PMK from the EAP exchange. This is more secure because the PMK changes every session.
- WPA3-SAE: PMK is derived from the SAE (Dragonfly) handshake — a zero-knowledge proof where the passphrase is never exposed, even to offline dictionary attacks.

Role of PMK in the 4-Way Handshake:

- The PMK is never transmitted over the air and never used directly for encryption. Its role is to prove that both the AP and client share the same secret, and to serve as the input for deriving the PTK.
- PTK Derivation: $PTK = PRF-X(PMK \parallel ANonce \parallel SNonce \parallel AP_MAC \parallel Client_MAC)$. The PTK is derived from the PMK combined with random nonces (ANonce and SNonce) and the MAC addresses of both devices. This ensures the PTK is unique for every session — even if the PMK is the same.
- Mutual Verification: The MIC (Message Integrity Code) in Messages 2 and 3 of the 4-Way Handshake is computed using the KCK (part of PTK). If both sides derived the correct PTK (which requires the correct PMK), the MICs match — this implicitly proves both sides know the same PMK without ever revealing it.
- Key Hierarchy Root: PTK is split into KCK (integrity verification), KEK (key encryption), and TK (actual data encryption). All three come from the PTK, which comes from the PMK.

PMK Lifetime and Caching:

- PMK Caching (802.11i): After a client disconnects, the AP can cache the PMK for a period. On reconnection, the client and AP can skip re-authentication and go directly to the 4-Way Handshake using the cached PMK (PMKID-based fast reconnect).
- In WPA3, forward secrecy means the PMK is derived fresh each session — past sessions cannot be decrypted even if the current PMK is compromised.

7. How does the 4-Way Handshake ensure mutual authentication between the client and the access point?

Answer:

The EAPOL 4-Way Handshake achieves mutual authentication implicitly — neither the AP nor the client ever directly reveals the PMK, but both prove they possess it through cryptographic verification using MIC (Message Integrity Code). Here is how each step contributes:

Message 1 – AP sends ANonce to Client:

- The AP sends a random 256-bit nonce (ANonce) to the client.
- The client now has: PMK (from PSK/EAP) + ANonce + SNonce (its own random value) + AP MAC + Client MAC.
- The client derives the full PTK = PRF(PMK, ANonce, SNonce, AP_MAC, Client_MAC).
- Authentication check: None yet — Message 1 has no MIC.

Message 2 – Client sends SNonce + MIC to AP:

- The client sends its SNonce and a MIC computed using KCK (first 128 bits of its derived PTK).
- The AP receives the SNonce, derives its own PTK using the same formula, and verifies the MIC.
- If the MIC is valid: The client must have derived the correct PTK, which means it must know the correct PMK. This proves the client's identity to the AP.
- AP authenticates the client here — this is the client proving it knows the PMK.

Message 3 – AP sends GTK + MIC to Client:

- The AP sends the GTK (Group Temporal Key) encrypted with KEK (part of PTK), along with a MIC computed using KCK.
- The client verifies the MIC using its own KCK.
- If the MIC is valid: The AP must have derived the correct PTK, which means the AP also knows the correct PMK. This proves the AP's identity to the client.
- Client authenticates the AP here — this is the AP proving it knows the PMK.
- The Install flag tells the client to install the PTK and begin encryption.

Message 4 – Client confirms to AP:

- The client sends a confirmation with a MIC — acknowledging receipt of the GTK and installation of keys.
- The AP verifies this final MIC and installs its PTK.
- Both sides now have matching, installed PTK and GTK — encrypted communication begins.

Why This is Mutual Authentication:

Step	Who is Authenticated	How
Message 2 MIC	Client authenticated to AP	Only a client with the correct PMK can compute a valid MIC — AP verifies it
Message 3 MIC	AP authenticated to Client	Only an AP with the correct PMK can compute a valid MIC — Client verifies it
Result	Both sides proven	Neither PMK was ever transmitted — proven through cryptographic MIC verification

This is why a rogue AP cannot impersonate a legitimate AP in WPA2 — it would need to know the PMK to compute a valid MIC in Message 3. If it sends an invalid MIC, the client rejects the handshake and does not install keys.

8. What will happen if we put a wrong passphrase during a 4-Way Handshake?

Answer:

When a wrong passphrase is entered, the EAPOL 4-Way Handshake will silently fail — the client and AP will derive different PTKs, causing MIC verification to fail. Here is the exact sequence of what happens:

Step-by-Step Failure Sequence:

- Step 1 – Wrong PMK Derived: The client derives the PMK using: $PMK = PBKDF2(wrong_passphrase, SSID, 4096 \text{ iterations})$. This PMK is different from the AP's PMK (derived from the correct passphrase).
- Step 2 – Wrong PTK Derived: Using the wrong PMK, the client derives an incorrect PTK. The KCK (used for MIC computation) is therefore also wrong.
- Step 3 – Message 2 sent with wrong MIC: The client sends its SNonce with a MIC computed using its incorrect KCK.
- Step 4 – AP MIC Verification Fails: The AP derives the PTK using its correct PMK and the client's SNonce. It computes what the MIC should be and compares it with the received MIC. They do not match — the AP detects the wrong passphrase.
- Step 5 – AP Silently Drops or Retries: The AP either silently discards Message 2 (no error response is sent) or in some implementations sends a new Message 1 (ANonce) to retry the handshake.
- Step 6 – Timeout and Deauthentication: After a configured number of retries (typically 3–4), the AP sends a Deauthentication frame to the client with Reason Code 23 (IEEE 802.1X authentication failed) or similar.
- Step 7 – Client Disconnects: The client receives the deauth and returns to the scanning/authentication state. In the user interface, this appears as 'Incorrect password' or 'Authentication failed'.

Important Security Note:

- No information about the correct passphrase is revealed during this process — the AP never sends back what the correct MIC should be.
- An attacker performing an offline dictionary attack captures the 4-Way Handshake frames (specifically Messages 1 and 2 containing the ANonce, SNonce, and MIC) and tries thousands of passphrases locally — computing PTK and checking if the MIC matches. This is why strong, long passphrases are important for WPA2-Personal.
- WPA3-SAE eliminates offline dictionary attacks entirely because the SAE handshake does not expose verifiable cryptographic material that can be tested offline.

What the User Sees:

- Windows/Android/iOS: 'Incorrect password' or 'Authentication error'
- The device disconnects and returns to the Wi-Fi selection screen.
- No connection is established and no data is transferred.

9. What problem does 802.1X solve in a network?

Answer:

The Core Problem: Lack of Identity-Based Access Control

Without 802.1X, traditional Wi-Fi networks using PSK (Pre-Shared Key) have a fundamental problem: everyone who knows the Wi-Fi password gets the same level of access. There is no way to distinguish between individual users, and no way to revoke access for one user without changing the password for everyone.

Problems That 802.1X Solves:

- **No Individual Identity:** With PSK, the network sees a device, not a user. 802.1X authenticates individual users or devices using unique credentials (username/password, digital certificates) — each person has their own identity on the network.
- **Shared Secret Vulnerability:** In PSK networks, if the password is leaked (by an ex-employee, for example), the entire network is compromised — every device must be reconfigured with a new password. With 802.1X, only the compromised user's account needs to be disabled on the RADIUS server — all other users are unaffected.
- **No Access Control:** PSK provides no ability to restrict what different users can access. 802.1X enables the RADIUS server to assign different VLANs, ACLs, or QoS policies based on the user's identity — different users get different levels of access.
- **No Audit Trail:** With PSK, there is no way to trace which user performed which action. 802.1X authentication logs on the RADIUS server provide a complete audit trail: who connected, when, from which device, and for how long.
- **Device Authentication Without Passwords:** 802.1X with EAP-TLS supports certificate-based authentication — a device presents a digital certificate instead of a password. This is more secure (no password to steal) and supports machine authentication before a user logs in.
- **Guest and BYOD Segregation:** 802.1X enables the network to automatically place employees on the corporate VLAN and guests or unmanaged devices on an isolated guest VLAN — based on their credentials, not a different SSID.

802.1X Architecture:

- **Supplicant:** The client device requesting access.
- **Authenticator:** The AP or switch — acts as a gatekeeper, blocking all traffic until authentication is complete.
- **Authentication Server:** The RADIUS server — holds the user database and makes the allow/deny decision.
- The AP blocks all traffic (except EAPOL frames) until the RADIUS server grants access.

10. How does 802.1X enhance security over wireless networks?

Answer:

802.1X (Port-Based Network Access Control) significantly enhances wireless security by adding identity-based authentication, dynamic key generation, and centralized policy enforcement on top of the existing WPA2/WPA3 encryption framework.

1. Per-User, Per-Session Encryption Keys:

- In WPA2-Personal (PSK), the PMK is derived from the same passphrase for all users — if one device is compromised, others using the same network could potentially be at risk.
- In WPA2-Enterprise (802.1X), the RADIUS server generates a unique PMK for each authentication session. Every user gets different session keys — compromise of one session's keys has zero impact on other users.
- This prevents passive eavesdropping attacks where a client captures another client's traffic and attempts to decrypt it.

2. Mutual Authentication (EAP-TLS, PEAP, EAP-TTLS):

- 802.1X with strong EAP methods provides mutual authentication — not only does the server verify the client, but the client also verifies the server's certificate.
- This prevents rogue AP and evil twin attacks — a fake AP cannot present a valid server certificate from the organization's PKI, so the client refuses to authenticate.
- EAP-TLS uses digital certificates on both client and server — the strongest form of Wi-Fi authentication, resistant to password theft.

3. Dynamic VLAN Assignment and Access Control:

- The RADIUS server can return VLAN attributes in the Access-Accept message, dynamically placing the user in the appropriate network segment based on their identity.

- An employee is placed in the corporate VLAN; a contractor in a restricted VLAN; a guest in an isolated VLAN — all using the same SSID but different network access.
- ACLs and QoS policies can also be pushed per-user — fine-grained access control based on identity.

4. Centralized User Management and Revocation:

- All user credentials are managed on the RADIUS server (often integrated with Active Directory / LDAP).
- Disabling an employee's account in Active Directory immediately revokes their Wi-Fi access — no password changes required network-wide.
- Time-based and device-based access policies can be enforced centrally.

5. Complete Audit Trail:

- RADIUS accounting logs every authentication event: username, device MAC, AP, session start/stop, data transferred.
- Provides forensic evidence for security investigations and compliance reporting (PCI-DSS, HIPAA, ISO 27001).

6. Protection Against Credential Theft:

- With EAP-TLS, there are no passwords to steal — only certificates.
- With PEAP/EAP-TTLS, credentials are transmitted inside a TLS tunnel — protected from interception.
- WPA3-Enterprise adds 192-bit security mode with GCMP-256 and ECDH for government and high-security deployments.

Security Feature	WPA2-Personal (PSK)	WPA2/3-Enterprise (802.1X)
Authentication	Shared passphrase	Individual credentials (password or certificate)
PMK per session	Same for all users	Unique per user per session
Rogue AP protection	None (no server certificate)	Yes — client verifies server certificate (EAP-TLS/PEAP)
Access revocation	Change password for everyone	Disable one user account on RADIUS
VLAN assignment	Static — same for all	Dynamic — per user identity
Audit trail	None (device MAC only)	Full per-user logging on RADIUS
Offline attack resistance	Vulnerable (PMKID/MIC capture)	Strong — no shared secret to crack